

LECTURE NOTES

Information System Security

Week 1

Information System Security Introduction

LEARNING OUTCOMES

LO1. Identify information system security items and aspect

OUTLINE MATERI (Sub-Topic):

1. Tenets of Information Systems Security
2. The Seven Domains of a Typical IT Infrastructure
3. Weakest Link in the Security of an IT Infrastructure
4. IT Security Policy Framework
5. Data Classification Standards

ISI MATERI

Saat ini internet sudah berkembang semakin luas. Penggunaanya sudah meningkat semakin tajam. Hal ini membuka banyak peluang baru dalam dunia komunikasi. Namun disisi lain, konektivitas yang semakin meluas ini membawa tantangan tersendiri. Ada banyak ancaman dan resiko yang muncul dari sini

Jika dilihat dari definisinya, Risk (resiko) adalah kemungkinan akan terjadi sesuatu yang buruk terhadap sebuah aset. Dalam hal IT security, aset dapat berupa sebuah computer, database, ataupun sebagian dari data.

Threat (ancaman) adalah segala sesuatu yang dapat membahayakan sebuah aset. Ada ancaman alami seperti bencana alam, ada juga yang disebabkan oleh perbuatan manusia. Jika mengalami gangguan akibat ancaman tersebut sebuah organisasi harus bisa segera memulihkan diri. Karena itu perusahaan perlu memiliki Business Continuity Plan (BCP) dan Disaster Recovery Plan (DRP). Dua dokumen ini menyatakan apa yang harus dilakukan organisasi jika mengalami bencana, dan memulihkan diri dari kerusakan yang dialami.

Vulnerability (celah keamanan) adalah kelemahan yang memungkinkan sebuah ancaman menyebabkan kerusakan terhadap sebuah aset.

Keamanan paling mudah didefinisikan bila dipecah menjadi beberapa bagian. Sebuah sistem informasi terdiri dari aplikasi perangkat keras, sistem operasi, dan perangkat lunak yang bekerja sama untuk mengumpulkan, memproses, dan menyimpan data baik untuk individu maupun organisasi. Keamanan sistem informasi adalah kumpulan aktivitas yang melindungi sistem informasi dan data yang disimpan di dalamnya. Banyak hukum di Amerika Serikat dan internasional sekarang membutuhkan jaminan keamanan jenis ini. Organisasi-organisasi harus menangani kebutuhan ini secara langsung.

Information system security adalah kumpulan aktivitas yang dilakukan untuk menjaga sistem informasi dan data yang disimpan didalamnya

Tenets of Information System Security

Ada tiga prinsip dasar terkait dengan keamanan sistem informasi. Tiga prinsip dasar itu adalah sebagai berikut.

- Availability (ketersediaan). Informasi bisa diakses oleh orang yang berhak
- Integrity. Hanya orang yang memiliki akses yang bisa merubah informasi
- Confidentiality. Hanya orang yang berhak yang dapat melihat informasi tersebut.

Availability

Availability secara umum di definisikan sebagai jumlah waktu user dapat mengakses sistem, aplikasi, dan data. Pengukuran waktu availability bisanya mencakup beberapa hal berikut ini

- Uptime. Jumlah total waktu sebuah sistem, aplikasi, dan data bisa diakses.
- Downtime. Jumlah total waktu sistem, aplikasi, dan data tidak dapat diakses.
- Availability. Perhitungan matematika dengan rumus $(\text{total uptime}) / (\text{total uptime} + \text{total downtime})$
- Mean time to failure (MTTF). Rata-rata waktu antara failure dalam sebuah sistem.
- Mean time to repair (MTTR). Rata-rata waktu yang diperlukan untuk memperbaiki sistem
- Recovery time Objective (RTO) jumlah waktu yang diperlukan untuk memulihkan sistem sehingga sistem, aplikasi, data bisa kembali diakses oleh user setelah terjadi failure.

Bagaimana mengukur availability

Dalam waktu 30 hari, total jumlah uptime sebuah sistem adalah:

$$30 \text{ hari} \times 24 \text{ jam/hari} \times 60 \text{ menit/jam} = 43.200 \text{ menit}$$

Dengan menggunakan rumus $\text{availability} = (\text{total uptime}) / (\text{total uptime} + \text{total downtime})$, maka sebuah sistem yang mengalami downtime 30 menit adalah:

$$\text{Availability} = (43.200 \text{ menit}) / (43.200 \text{ menit} + 30 \text{ menit}) = 0.9993 \text{ atau } 99.93\%$$

Integrity

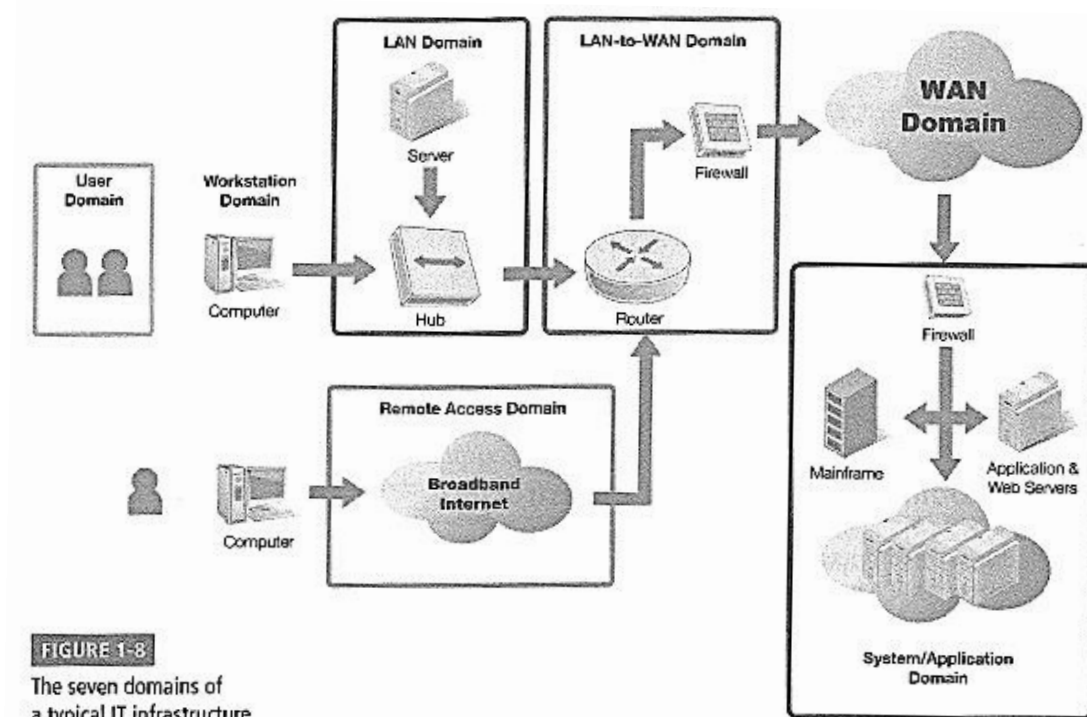
Integrity melihat data dari sisi validitas dan akurasi data tersebut. Data yang tidak memiliki integrity adalah data yang tidak akurat dan tidak valid. Pada beberapa perusahaan, data bisa saja berupa hak paten ataupun formula rahasia. Sehingga perubahan yang tidak disetujui dapat mengurangi nilai data tersebut.

Confidentiality

Confidentiality maksudnya adalah menjaga informasi dari semua orang, kecuali orang yang berhak atas data tersebut.

The Seven Domains of a typical IT infrastructure

Sebuah infrastruktur IT biasanya terdiri dari tujuh domain. Setiap domain ini membutuhkan kontrol keamanan yang sesuai. Setiap kontrol ini harus memenuhi prinsip A-I-C diatas.



Tujuh domain yang umum ada didalam infrastuktur IT

User domain

Mendefinisikan user dan orang-orang yang bisa mengakses sistem informasi dalam sebuah organisasi.

Tugas dan peran: user bisa mengakses sistem sesuai dengan hak akses yang dimilikinya

Tanggung jawab: user bertanggungjawab untuk penggunaan aset IT tersebut

Accountability: departemen SDM harus memastikan identitas karyawan sebelum mengijinkan karyawan mengakses sistem internal perusahaan

Berikut ini adalah risk, threats, vulnerability, dan mitigation plan yang ada di user domain

RISK, THREAT, OR VULNERABILITY	MITIGATION
Lack of user awareness	Conduct security awareness training, display security awareness posters, insert reminders in banner greetings, and send e-mail reminders to employees.
User apathy toward policies	Conduct annual security awareness training, implement acceptable use policy, update staff manual and handbook, discuss during performance reviews.
Security policy violations	Place employee on probation, review AUP and employee manual, discuss during performance reviews.
User inserts CDs and USB drives with personal photos, music, and videos.	Disable internal CD drives and USB ports. Enable automatic antivirus scans for inserted media drives, files, and e-mail attachments. An antivirus scanning system examines all new files on your computer's hard drive for viruses. Set up antivirus scanning for e-mails with attachments.
User downloads photos, music, and videos.	Enable content filtering and antivirus scanning for e-mail attachments. Content-filtering network devices are configured to permit or deny specific domain names in accordance with AUP definition.
User destruction of systems, applications, or data	Restrict access for users to only those systems, applications, and data needed to perform their job. Minimize write/delete permissions to the data owner only.
Disgruntled employee attacks the organization or commits sabotage.	Track and monitor abnormal employee behavior, erratic job performance, and use of IT infrastructure during off-hours. Begin IT access control lockdown procedures based on AUP monitoring and compliance.

Employee romance gone bad

Track and monitor abnormal employee behavior and use of IT infrastructure during off-hours. Begin IT access control lockout procedures based on AUP monitoring and compliance.

Employee blackmail or extortion

Track and monitor abnormal employee behavior and use of IT infrastructure during off-hours. Enable intrusion detection system/intrusion prevention system (IDS/IPS) monitoring for sensitive employee positions and access. IDS/IPS security appliances examine the IP data streams for inbound and outbound traffic. Alarms and alerts programmed within an IDS/IPS help identify abnormal traffic and can block IP traffic as per policy definition.

Table resiko di user domain

Workstation Domain

Area dimana user terhubung dengan infrastruktur IT. Workstation bisa saja berupa komputer desktop, laptop, atau perangkat lainnya yang terhubung dengan jaringan

Tugas dan peran: staff organisasi harus memiliki akses terhadap apapun yang menunjang produktifitas mereka

Tanggung jawab: bagian desktop support bertanggung jawab terhadap domain ini.

Accountability: IT desktop manager bertanggung jawab mengujinkan karyawan untuk menggunakan workstation domain

Berikut ini adalah risk, threats, vulnerability, dan mitigation plan yang ada di workstation domain

RISK, THREAT, OR VULNERABILITY	MITIGATION
Unauthorized access to workstation	Enable password protection on workstations for access. Enable auto screen lockout for inactive times.
Unauthorized access to systems, applications, and data	Define strict access control policies, standards, procedures, and guidelines. Implement a second-level test to verify a user's right to gain access.
Desktop or laptop computer operating system software vulnerabilities	Define workstation operating system vulnerability window policy definition. A vulnerability window is the gap in time that you leave a computer unpatched with a security update. Start periodic Workstation Domain vulnerability tests to find gaps.
Desktop or laptop application software vulnerabilities and software patch updates	Define a workstation application software vulnerability window policy. Update application software and security patches according to defined policies, standards, procedures, and guidelines.
Viruses, malicious code, or malware infects a user's workstation or laptop computer.	Use workstation antivirus and malicious code policies, standards, procedures, and guidelines. Enable an automated antivirus protection solution that scans and updates individual workstations with proper protection.
User inserts compact disks (CDs), digital video disks (DVDs), or universal serial bus (USB) thumb drive into organization computer.	Deactivate all CD, DVD, and USB ports. Enable automatic antivirus scans for inserted CDs, DVDs, and USB thumb drives that have files.
User downloads photos, music, or videos via the Internet.	Use content filtering and antivirus scanning at Internet entry and exit. Enable workstation auto-scans for all new files and automatic file quarantine for unknown file types.
User violates AUP and creates security risk for the organization's IT infrastructure.	Mandate annual security awareness training for all employees. Set up security awareness campaigns and programs throughout the year.

Table resiko di domain workstation

LAN Domain

Local area network adalah kumpulan computer yang terhubung satu sama lain melalui media komunikasi seperti kabel jaringan, wireless, dll. Beberapa bagian dari LAN domain adalah: network interface card, kabel LAN, switch, server, wireless access point.

Tugas dan peran: LAN domain terdiri dari komponen fisik dan logis untuk menghubungkan user

Tanggung jawab: bagian jaringan bertanggung jawab untuk LAN domain

Accountability: manager LAN bertugas untuk memaksimalkan penggunaan dan integritas data dalam LAN domain.

Berikut ini adalah risk, threats, vulnerability, dan mitigation plan yang ada di LAN domain

RISK, THREAT, OR VULNERABILITY	MITIGATION
Unauthorized access to LAN	Make sure wiring closets, data centers, and computer rooms are secure. Do not allow anyone access without proper ID.
Unauthorized access to systems, applications, and data	Define strict access control policies, standards, procedures, and guidelines. Implement second-level identity check to gain access to sensitive systems, applications, and data.
LAN server operating system software vulnerabilities	Define server/desktop/laptop vulnerability window policies, standards, procedures, and guidelines. Conduct periodic LAN Domain vulnerability assessments to find software gaps. A vulnerability assessment is a software review that identifies bugs or errors in software. These bugs and errors go away when you upload software patches and fixes.
LAN server application software vulnerabilities and software patch updates	Define a strict software vulnerability window policy requiring quick software patching.
Rogue users on WLANs gain unauthorized access.	Use WLAN network keys that require a password for wireless access. Turn off broadcasting on WAPs. Require second-level authentication prior to granting WLAN access.
Confidentiality of data transmissions via WLAN connections is compromised.	Implement encryption between workstation and WAP to maintain confidentiality.
LAN servers have different hardware, operating systems, and software, making it difficult to manage and troubleshoot.	Implement LAN server and configuration standards, procedures, and guidelines.

Table resiko di domain LAN

LAN-to-WAN Domain

Adalah domain dimana infrastruktur IT terhubung dengan wide area network dan internet. Merupakan salah satu domain yang penting. Karena dengan terhubung dengan internet, kita membuka diri terhadap akses publik, termasuk dengan segala bahayanya.

Tugas dan peran: memastikan konektifitas fisik dan logis bisa terhubung dengan baik

Tanggung jawab: domain ini merupakan tanggung jawab dari bagian jaringan.

Accountability: manager network WAN bertanggung jawab untuk mengelola domain ini

Berikut ini adalah risk, threats, vulnerability, dan mitigation plan yang ada di LAN-to-WAN domain

RISK, THREAT, OR VULNERABILITY	MITIGATION
Unauthorized network probing and port scanning	Disable ping, probing, and port scanning on all exterior IP devices within the LAN-to-WAN Domain. Ping uses the Internet Control Message Protocol (ICMP) echo-request and echo-reply protocol. Disallow IP port numbers used for probing and scanning and monitor with IDS/IPS.
Unauthorized access through the LAN-to-WAN Domain	Apply strict security monitoring controls for intrusion detection and prevention. Monitor for inbound IP traffic anomalies and malicious-intent traffic. Block traffic right away if malicious.
IP router, firewall, and network appliance operating system software vulnerability	Define a strict zero-day vulnerability window definition. Update devices with security fixes and software patches right away.
IP router, firewall, and network appliance configuration file errors or weaknesses	Conduct post configuration penetration tests of the layered security solution within the LAN-to-WAN Domain. Test inbound and outbound traffic and fix any gaps.

Remote users can access the organization's infrastructure and download sensitive data	Apply and enforce the organization's data classification standard. Deny outbound traffic using source IP addresses in access control lists. If remote downloading is allowed, encrypt where necessary.
Local users download unknown file type attachments from unknown sources	Apply file transfer monitoring, scanning, and alarming for unknown file types from unknown sources.
Local users receive unknown e-mail attachments and embedded URL links	Apply e-mail server and attachment antivirus and e-mail quarantining for unknown file types. Stop domain-name Web site access based on content-filtering policies.
Local users lose productivity surfing the Web and not focusing on work tasks.	Apply domain-name content filtering at the Internet entry/ access point.

Table resiko di LAN-to-WAN domain

WAN Domain

Menghubungkan area-area yang berjauhan. Beberapa organisasi memiliki cabang yang lokasinya berjauhan. Lokasi yang berbeda ini dihubungkan dengan jaringan komputer melalui WAN.

Tugas dan peran: menghubungkan lokasi-lokasi yang berjauhan, termasuk didalamnya konfigurasi fisik dan logis dari router dan perangkat komunikasi lainnya.

Tanggung jawab: network engineer bertanggungjawab untuk domain ini

Accountability: IT network manager harus mengelola dan memberikan dukungan teknis terhadap WAN domain.

Berikut ini adalah risk, threats, vulnerability, dan mitigation plan yang ada di WAN domain

RISK, THREAT, OR VULNERABILITY

MITIGATION

Open, public, easily accessible to anyone that wants to connect

Apply acceptable use policies, in accord with the document "RFC 1087: Ethics and the Internet." Enact new laws regarding unauthorized access to systems, malicious attacks on IT infrastructures, and financial loss due to malicious outages.

Most Internet traffic is sent in cleartext.

Prohibit using the Internet for private communications without encryption and VPN tunnels. If you have a data classification standard, follow the policies, procedures, and guidelines specifically.

Vulnerable to eavesdropping

Use encryption and VPN tunnels for end-to-end secure IP communications. If you have a data classification standard, follow the policies, procedures, and guidelines.

Vulnerable to malicious attacks

Deploy layered LAN-to-WAN security countermeasures, DMZ with IP stateful firewalls, IDS/IPS for security monitoring, and quarantining of unknown e-mail file attachments.

Vulnerable to denial of service (DoS), distributed denial of service (DDoS), TCP SYN flooding, and IP spoofing attacks

Apply filters on exterior IP stateful firewalls and IP router WAN interfaces to block TCP SYN and ICMP (ping). Alert your Internet service provider (ISP) to put the proper filters on its IP router WAN interfaces in accordance with CERT Advisory CA-1996-21.

Vulnerable to corruption of information and data

Encrypt IP data transmissions with VPNs. Back up and store data in off-site data vaults (online or physical data backup) with tested recovery procedures.

TCP/IP applications are inherently insecure (HTTP, FTP, TFTP, etc.).

Refer to your data classification standard for proper handling of data and use of TCP/IP applications. Never use TCP/IP applications for confidential data without proper encryption. Create a network-management VLAN and isolate TFTP and SNMP traffic used for network management.

Hackers, attackers, and perpetrators e-mail Trojans, worms, and malicious software freely.

Scan all e-mail attachments for type, antivirus, and malicious software at the LAN-to-WAN Domain. Isolate and quarantine unknown file attachments until further security review is conducted. Provide security awareness training to remind employees of dangers.

Table resiko di WAN domain

Remote Access Domain

Domain ini menghubungkan remote user ke infrastruktur IT organisasi

Tugas dan peran: menghubungkan mobile user ke IT organisasi melalui internet

Tanggung jawab: network engineer bertanggungjawab untuk area ini

Accountability: WAN network manager bertanggungjawab untuk memastikan standard, metoden dan guideline yang digunakan.

Berikut ini adalah risk, threats, vulnerability, dan mitigation plan yang ada di remote access domain

RISK, THREAT, OR VULNERABILITY	MITIGATION
Brute-force user ID and password attacks	Establish user ID and password policies requiring periodic changes (i.e., every 30 or 60 days). Passwords must be used, passwords must have more than eight characters, and users must incorporate numbers and letters.
Multiple logon retries and access control attacks	Set automatic blocking for attempted logon retries (e.g., block user access after three logon attempts have failed).
Unauthorized remote access to IT systems, applications, and data	Apply first-level (i.e., user ID and password) and second-level (i.e., tokens, biometrics, and smart cards) security for remote access to sensitive systems, applications, and data.
Private data or confidential data is compromised remotely.	Encrypt all private data within the database or hard drive. If data is stolen, the thief cannot use or sell it because it will be encrypted.
Data leakage in violation of existing data classification standards	Apply security countermeasures in the LAN-to-WAN Domain including data leakage security-monitoring tools and tracking as per your organization's data classification standard.
Mobile worker laptop is stolen.	Encrypt the data on the hard drive if the user has access to private or confidential data. Apply real-time lockout rules when told of a lost or stolen laptop by a user.
Mobile worker token or other authentication stolen	Apply real-time lockout procedures if a token is lost or device is compromised.

Table resiko di Remote Access Domain

Domain Sistem/Aplikasi

Domain Sistem/Aplikasi menampung semua sistem, aplikasi, dan data. Pengguna yang berwenang mungkin memiliki akses ke banyak komponen ke dalam domain ini. Akses yang aman mungkin memerlukan pemeriksaan dua tahap.

Contoh aplikasi yang mungkin memerlukan otentikasi tingkat kedua adalah sebagai berikut:

- Sumber daya manusia dan staf *payroll*-Hanya staf yang bekerja di layanan *payroll* memerlukan akses ke data pribadi dan informasi yang sifatnya rahasia ini.
- Manajer akuntansi dan keuangan-Manajer eksekutif membutuhkan akses ke data akuntansi dan keuangan untuk membuat keputusan bisnis yang bijaksana. Mengamankan data keuangan membutuhkan kontrol keamanan yang unik dengan akses terbatas bagi mereka yang membutuhkannya.
- Perusahaan yang sifatnya terbuka tunduk pada undang-undang kepatuhan Sarbanes-Oxley (SOX) yang membutuhkan keamanan.
- *Customer relationship management* (CRM)-Perwakilan layanan pelanggan membutuhkan akses terbaru yang *real-time* untuk informasi seperti riwayat pembelian dan data pribadi pelanggan.

Berikut ini adalah beberapa resiko

RISK, THREAT, OR VULNERABILITY	MITIGATION
Unauthorized access to data centers, computer rooms, and wiring closets	Apply policies, standards, procedures, and guidelines for staff and visitors to secure facilities.
Servers must sometimes be shut down to perform maintenance.	Create a system that brings together servers, storage, and networking.
Server operating systems software vulnerability	Define vulnerability window for server operating system environments. Maintain hardened production server operating systems.
Cloud computing virtual environments are by default not secure.	Implement virtual firewalls and server segmentation on separate VLANs. A virtual firewall is a software-based firewall used in virtual environments.
Client-server and Web applications are susceptible to attack.	Conduct rigorous software and Web-application testing and penetration testing prior to launch.
Unauthorized accessed to systems.	Follow data classification standards regarding stringent use of second-level authentication.
Private data is compromised.	Separate private data elements into different databases. For archiving purposes, encrypt data within databases and storage devices.
Data is corrupted or lost.	Implement daily data backups and off-site data storage for monthly data archiving. Define data recovery procedures based on defined RTOs.
Backed-up data may be lost as backup media is reused.	Convert all data into digital data for long-term storage. Retain backups from off-site data vaults based on defined RTOs.
Recovering critical business functions may take too long to be useful.	Develop a business continuity plan for mission-critical applications providing tactical steps for maintaining availability of operations.
IT systems may be down for an extended period after a disaster.	Develop a disaster recovery plan specific to the recovery of mission-critical applications and data to maintain operations.

Table resiko di domain aplikasi

Weakest Link in The Security

Pengguna adalah hubungan terlemah dalam keamanan. Bahkan praktisi keamanan sistem informasi masih bisa membuat kesalahan. Kesalahan manusia adalah risiko dan ancaman utama bagi organisasi mana pun. Tidak ada kelompok yang bisa mengendalikan mengontrol perilaku seseorang secara seutuhnya. Karena inilah, setiap organisasi harus mempersiapkan

diri pengguna jahat, pengguna yang tidak terlatih, dan pengguna yang kurang berhati-hati. Strategi berikut dapat membantu mengurangi risiko:

Periksa latar belakang setiap kandidat pekerja dengan cermat. Evaluasi anggota staf secara berkala. Pindah tangankan akses ke sistem, aplikasi, dan data sensitif kepada staf dengan posisi berbeda. Terapkan aplikasi suara dan pengujian perangkat lunak dan ulasan untuk kualitas. Tinjau rencana keamanan secara berkala di seluruh tujuh domain khusus sistem TI. Lakukan audit guna mengontrol keamanan secara tahunan. Untuk membangun profesi yang dihormati dan efektif, ahli keamanan sistem informasi harus beroperasi secara etis dan mematuhi kode etik. Bagian ini menjelaskan alasan mengapa ini adalah dasar dari profesinya..

IT security Policy Framework

Untuk memastikan standar dan aturan mengenai keamanan diperlukan sebuah framework. Framework ini berisi policy, standar, procedures, dan guideline yang mengurangi risk dan threats

Ada empat komponen utama dalam IT security framework

- Policy. Pernyataan singkat tertulis mengenai arahan dari pimpinan perusahaan
- Standard: definisi detail tertulis mengenai hardware dan software dan cara penggunaannya
- Procedures: instruksi tertulis bagaimana menjalankan policy dan standards
- Guidelines: arahan untuk menjalankan policy

Fokus kerangka kerja kebijakan keamanan TI untuk organisasi Anda adalah untuk mengurangi peluang Anda terhadap paparan risiko, ancaman, dan kerentanan. Penting untuk mengaitkan definisi kebijakan dan standar untuk persyaratan desain praktis. Persyaratan-persyaratan ini akan menerapkan kontrol keamanan dan penanggulangan terbaik secara layak. Pernyataan kebijakan harus menetapkan batasan dan juga mengacu pada standar, prosedur, dan pedoman yang berlaku. Kebijakan menentukan bagaimana kontrol keamanan dan tindakan pencegahan harus digunakan untuk mematuhi hukum dan peraturan.

Beberapa contoh IT security policy adalah sebagai berikut

- Acceptable use policy (AUP). AUP mendefinisikan apa yang boleh dan tidak boleh dilakukan dengan aset IT perusahaan
- Security awareness policy. Policy yang mendefinisikan bagaimana memastikan semua karyawan memahami pentingnya keamanan
- Asset classification policy. Policy ini mendefinisikan klasifikasi data dalam perusahaan.
- Asset management policy
- Threat assesment and monitoring
- Vulnerability assesment and management

Untuk memastikan bagaimana perusahaan mengelola data rahasia dengan baik secara konsisten, diperlukan data classification standards. Umumnya ada empat kategori klasifikasi data

- Private data. Data yang harus disimpan untuk pribadi
- Confidential. Data yang dimiliki oleh perusahaan.
- Internal use only. Data yang di bagikan khusus untuk karyawan internal perusahaan
- Public domain data. Informasi yang di publikasikan keluar perusahaan.

Tergantung pada standar klasifikasi data organisasi Anda, Anda mungkin perlu mengenkripsi data dengan sensitivitas tertinggi bahkan di perangkat penyimpanan dan hard drive. Sebagai contoh, Anda mungkin perlu menggunakan enkripsi dan teknologi VPN saat menggunakan Internet di tempat umum untuk akses jarak jauh. Tetapi komunikasi LAN internal dan akses ke sistem, aplikasi, atau data mungkin tidak memerlukan enkripsi. Pengguna juga dapat dibatasi untuk mengakses data pribadi pelanggan dan mungkin hanya dapat mengakses data tertentu. Perwakilan layanan pelanggan dapat menyediakan layanan pelanggan tanpa perlu mengakses ke data pribadi semua pelanggan. Contohnya, mereka mungkin tidak bisa melihat data pribadi yang sensitif seperti nomor Jamsostek atau nomor rekening pelanggan. Mereka hanya bisa melihat yang empat digit terakhir dari data pribadi tersebut.

SIMPULAN

Risk (resiko) adalah kemungkinan akan terjadi sesuatu yang buruk terhadap sebuah aset. Dalam hal IT security, aset dapat berupa sebuah computer, database, ataupun sebagian dari data.

Threat (ancaman) adalah segala sesuatu yang dapat membahayakan sebuah aset. Ada ancaman alami seperti bencana alam, ada juga yang disebabkan oleh perbuatan manusia.

Vulnerability (celah keamanan) adalah kelemahan yang memungkinkan sebuah ancaman menyebabkan kerusakan terhadap sebuah aset.

Information system security adalah kumpulan aktivitas yang dilakukan untuk menjaga sistem informasi dan data yang disimpan didalamnya

Ada tiga prinsip dasar terkait dengan keamanan sistem informasi. Tiga prinsip dasar itu adalah sebagai berikut.

- Availability (ketersediaan). Informasi bisa diakses oleh orang yang berhak
- Integrity. Hanya orang yang memiliki akses yang bisa merubah informasi
- Confidentiality. Hanya orang yang berhak yang dapat melihat informasi tersebut.

Empat kategori klasifikasi data

- Private data. Data yang harus disimpan untuk pribadi
- Confidential. Data yang dimiliki oleh perusahaan.
- Internal use only. Data yang di bagikan khusus untuk karyawan internal perusahaan
- Public domain data. Informasi yang di publikasikan keluar perusahaan.

DAFTAR PUSTAKA

1. Kim, David. And Michael G. Solomon,(2012), **Fundamentals of Information System Security**, Jones & Bartlett Learning, Sudbury